

2025 Annual HIPAA & Security Training

The Shield of Patient Trust

Mandatory Operational Guide for Clinical & Support Staff



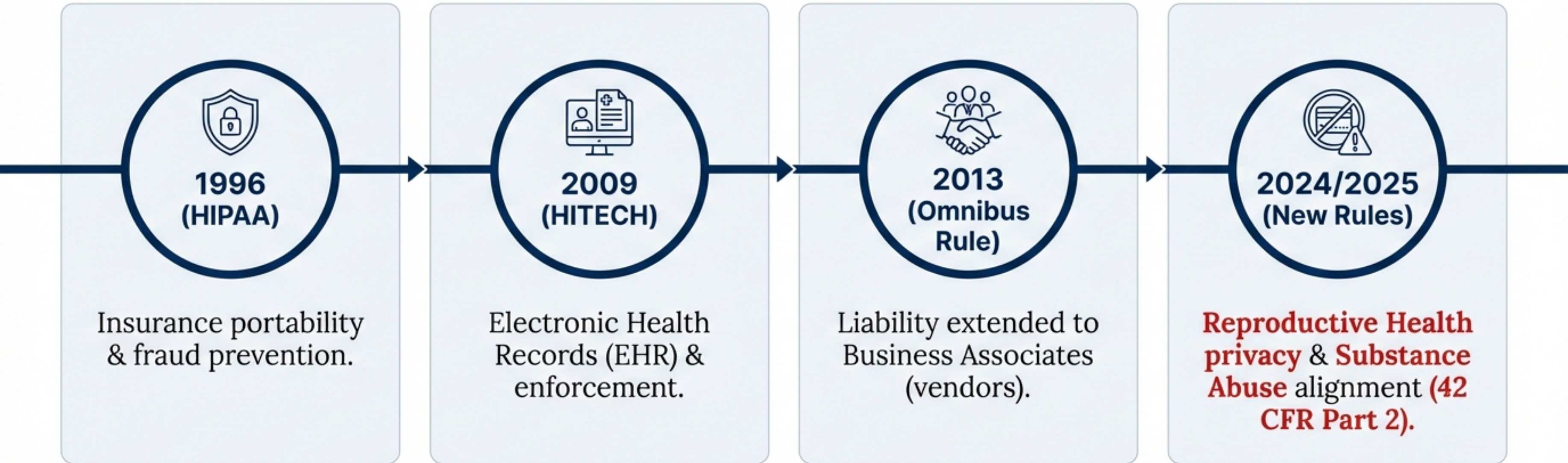
Core Message

Privacy is not just a legal requirement; it is a clinical tool. In addiction and psychiatric care, treatment cannot succeed without the absolute assurance of confidentiality.

Key Training Scope

- **Privacy Rule:** Authorization and Patient Rights (2024/2025 Updates)
- **Security Rule:** Technical safeguards and digital hygiene
- **Florida Statutes:** Specifics on FIPA and state-level breach notification

Trust is the Foundation of Recovery



The Clinical Reality: If patients do not trust us with their data, they will not trust us with their history. In psychiatric and addiction care, a breach does not just embarrass a patient; it can destroy their recovery and livelihood.

Defining the Asset: What is Protected Health Information (PHI)?

Definition: PHI is any information that relates to past, present, or future health/payment AND can identify the individual.

Direct Identifiers



Name, SSN, Telephone/Fax numbers, Email addresses.

Service Identifiers



Medical Record Numbers, Health Plan Beneficiary numbers, Account numbers.

Biometric & Visual



Full-face photos, Fingerprints, Voiceprints.

Technical & Dates



IP Addresses, Web URLs, Device Serial Numbers. All dates (admission, birth, death) except year alone.



WARNING:

Even “hallway talk” or a patient’s presence in a specific clinic (like addiction recovery) constitutes PHI and must be protected.

The Two Pillars: Privacy vs. Security

The Privacy Rule

The Who & Why



- Focus: Authorization and Rights.
- Definition: Controls WHO is authorized to access patient information and under WHAT circumstances.
- Managed by: Policies, Procedures, and the Notice of Privacy Practices (NPP).

The Security Rule

The How



- Focus: Technical Safeguards for ePHI.
- Definition: The ability to control access and protect information from accidental or intentional intrusion.
- Managed by: Encryption, Passwords, Firewalls, and Physical Locks.

Key Takeaway: Privacy is the **policy; Security is the **lock on the door**.**

The Patient's Bill of Rights & The NPP

Patient Rights Checklist

- ✓ • **Access:** Right to inspect and copy medical records.
- ✓ • **Amendment:** Right to request corrections to records.
- ✓ • **Accounting:** Right to know who has seen their data.
- ✓ • **Restriction:** Right to ask for limits on data usage.
- ✓ • **Confidentiality:** Right to request alternative communication methods.

The Notice of Privacy Practices (NPP)

Must be offered on the first visit.
Acknowledgement of receipt must be signed and filed.

NOTICE OF PRIVACY PRACTICES

Purpose of This Notice
This notice is to inform you of our policies and practices regarding the collection, use, and disclosure of your personal information. We are required by law to provide this notice to you.

Your Rights

- **Access:** You have the right to inspect and review our records that contain information about you.
- **Amendment:** You have the right to request that we amend or correct any errors in the information we have about you.
- **Restriction:** You have the right to request that we restrict or limit the collection, use, or disclosure of your information.
- **Accounting:** You have the right to request a list of all persons or entities to whom we have disclosed your information.
- **Confidentiality:** You have the right to request that we take certain steps to protect the confidentiality of your information.

Our Responsibilities
We are responsible for ensuring that your personal information is collected, used, and disclosed in accordance with the law. We will take reasonable steps to protect your information from unauthorized access, use, or disclosure.

Respect Instructions
We will respect your instructions regarding the collection, use, and disclosure of your information. If you have any questions or concerns, please contact us at the information provided below.

Contact Information
If you have any questions or concerns, please contact us at the information provided below.

Signature: _____
Date: _____

The Golden Rule: Minimum Necessary

Use or disclose only the specific amount of PHI necessary to accomplish the immediate task. Distinguish “Need to Know” from “Nice to Know”.

Operational Scenarios	
Scenario	Verdict
Doctors/Nurses sharing full history for care?	✅ Allowed
Billing sending full clinical notes when only a diagnostic code is needed?	❌ Violation
Discussing a patient by name in a crowded waiting room?	❌ Violation
Accessing a colleague's or family member's record out of curiosity?	❌ MAJOR VIOLATION (Termination Offense)

“Every action you take with patient information has a ripple effect.”

CRITICAL UPDATE: 2024/2025 Reproductive Health Privacy

NEW LAW

The New Mandate (Dec 2024 Deadline)

PHI related to lawful reproductive health care cannot be used or disclosed for investigating or imposing liability on any person seeking or providing such care.

Attestation Requirement



Must obtain signed attestation confirming requests are NOT for prohibited purposes (even from law enforcement).

NPP Update



Notice of Privacy Practices must be updated by Feb 16, 2026.

BAA Updates



Vendor agreements must include reproductive health protection language.

MCA
MARYLAND CHIROPRACTIC ASSOCIATION

Maryland Chiropractic Association

NotebookLM

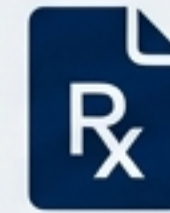
The Florida Layer: FIPA & State Statutes

FIPA (Florida Information Protection Act)



- **Broader Scope:** Personal info includes User Name/Email + Password/Security Answer.
- **Stricter Notification:** HIPAA allows 60 days. Florida requires notification to the Dept. of Legal Affairs within 30 DAYS.

Florida Statute 466.057



Strict confidentiality. Ownership of records belongs to the provider; access rights belong to the patient.



Major Breach Rule

In Florida, if a breach affects >500 individuals, we must notify the **Florida Dept. of Legal Affairs Affairs** AND major media outlets in the area.

Digital Hygiene: Keys to the Castle

The Password Policy

Correct-Horse-Battery-Staple



Strong

- **Length:** Minimum of 12 characters.
- **Complexity:** Use a passphrase.
- **The Cardinal Sin:** NEVER share your password. It is your digital signature.

Workstation Security



- **Lock It:** Windows Key + L every time you step away.
- **Positioning:** Screens turned away from public view.
- **No Piggybacking:** Do not let others use a terminal logged in under your name.

The Danger Zones: Email, Texting & Cloud



Email

⚠ Do not use personal Gmail, Yahoo, or Hotmail for PHI. Use encrypted organization email ONLY.



Cloud Storage

⚠ Prohibited unless an enterprise account with a BAA is in place.



Texting

⚠ Standard SMS is NOT secure. Use approved secure messaging apps only.

Device Control

- Encryption: All mobile devices with ePHI must be encrypted.
- BYOD: No patient photos on personal phones.
- USB Drives: Clinic-issued and encrypted only.

The Human Firewall: Responding to Social Engineering

Anatomy of a Phishing Email



IT Dept Support <support@microsoft-updates.com>

To: [Redacted]

Subject: Urgent Action Required: Your Account Will Be Suspended

Dear Employee,

To prevent immediate account suspension due to a security breach, please click the link below to verify your credentials. Attached is your updated security policy for review.



Unpaid_Invoice_23045.zip

**Mismatched
URL/Sender**

Urgency Threats

Unexpected Invoice

Physical Engineering

- Tailgating through secure doors.
- Fake Tech Support calls asking for passwords.

If suspicious: Do NOT forward. Call IT immediately.

Partners in Compliance: Business Associates (BA)



Who is a BA? Any vendor that creates, receives, maintains, or transmits PHI on our behalf.

The Rule: No PHI can be shared until a Business Associate Agreement (BAA) is signed. This legally binds them to HIPAA/FIPA standards.



Staff Responsibility Warning

Do not sign up for free online tools (e.g., "Free PDF Converter") to process patient data. They are likely not compliant.

Anatomy of a Breach

Definition: An impermissible use or disclosure under the Privacy Rule that compromises the security or privacy of the PHI.

The Presumption of Guilt: Under the Omnibus Rule, any impermissible use is PRESUMED TO BE A BREACH unless we can prove there is a low probability of compromise.

Risk Assessment Factors



Nature/Extent of PHI



Who received it?



Was it viewed/acquired?



Mitigation extent

Examples listed at the bottom: Lost laptop = Breach. Fax to wrong number = Breach. Gossip = Breach.

Response & Responsibility: Reporting Protocols

Emergency Contact Card



The Protocol: See Something, Say Something. Do not investigate yourself. Do not hide it.



Non-Retaliation Policy: Reports can be made anonymously. No retaliation for good faith reporting.

PRIVACY OFFICER: SoHa Ahmed

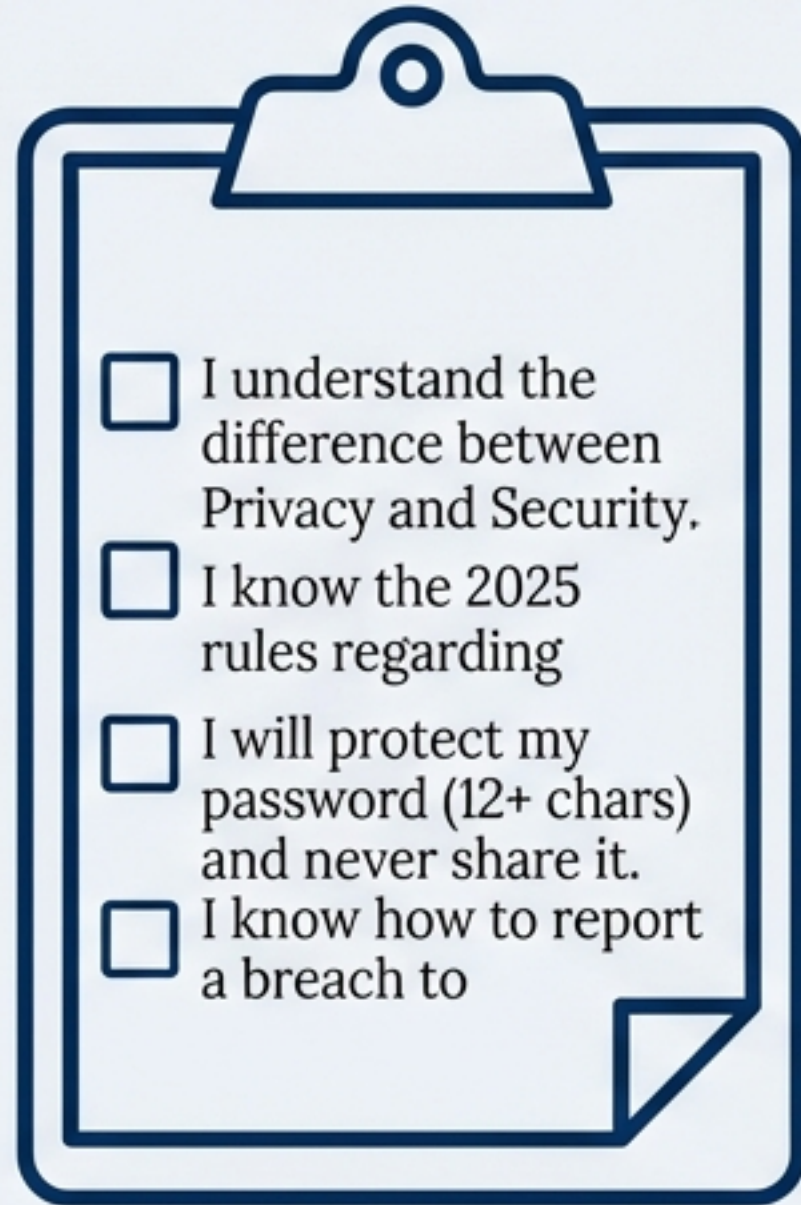
PHONE: 727-440-5612

EMAIL: s_ahmed@apcare.net



Sanctions: Violations result in tiered sanctions, from retraining to termination.

Final Attestation & Next Steps



- ☐ I understand the difference between Privacy and Security.
- ☐ I know the 2025 rules regarding Reproductive Health privacy.
- ☐ I will protect my password (12+ chars) and never share it.
- ☐ I know how to report a breach to SoHa Ahmed.

MANDATORY ACTION:

1. Complete the training quiz.
2. Sign and date the attestation statement.
3. Submit certificate to HR/Front Desk immediately.

Compliance protects everyone: The Patient, The Clinic, and You.